SAECOIN — Security Disclosure Policy

Document Version: 1.0
Project: SAECOIN
Ticker: SAC (Provisional)
Status: Draft — Proposed Security Policy

---

1. Purpose

This policy defines how security vulnerabilities affecting SAECOIN should be reported, investigated, resolved, and disclosed.

The objective is to protect:

- Blockchain consensus and network integrity.
- User wallets and private keys.
- Transactions and funds.
- Full nodes and peer-to-peer communication.
- Mining operations.
- Explorer and API services.
- Development infrastructure and release systems.

This policy applies to all official SAECOIN software and infrastructure maintained by the project.

2. Scope

Security reports may cover:

2.1 Blockchain Core

- Consensus vulnerabilities.
- Block validation errors.
- Transaction validation errors.
- Double-spending vulnerabilities.
- Chain reorganization weaknesses.
- Incorrect reward or supply calculations.
- Difficulty adjustment manipulation.
- Cryptographic implementation weaknesses.

2.2 Wallet Software

- Private-key exposure.
- Seed phrase leakage.
- Weak key generation.
- Incorrect transaction signing.

- Wallet encryption weaknesses.
- Backup and recovery vulnerabilities.
- Unauthorized transaction creation.

2.3 Network and Node

- Peer-to-peer protocol weaknesses.
- Remote code execution.
- Denial-of-service vulnerabilities.
- Malformed block or transaction handling.
- Network isolation and eclipse attacks.
- Unauthorized access to node services.

2.4 Supporting Services

- Explorer vulnerabilities.
- API authentication weaknesses.
- Database exposure.
- Server misconfiguration.
- Build and release infrastructure compromise.
- Dependency vulnerabilities.

3. Out of Scope

The following are generally not security vulnerabilities unless they demonstrate a direct security impact:

- General feature requests.
- Cosmetic UI problems.
- Ordinary performance complaints.
- Unsupported software versions.
- Issues caused solely by incorrect user configuration.
- Publicly known issues already documented by the project.

Reports should explain a realistic security impact.

4. How to Report a Vulnerability

Official security contact:
[SECURITY EMAIL — TO BE ADDED]

Alternative secure reporting channel:
[TO BE ADDED]

Until official reporting channels are established, the project must not claim to operate a formal private vulnerability-reporting service.

A report should include:

1. Vulnerability title.
2. Affected software or component.
3. Affected version or commit.
4. Technical description.
5. Steps to reproduce.
6. Proof of concept, where safe.
7. Potential impact.
8. Suggested mitigation, if known.

Do not include real private keys, seed phrases, passwords, or other sensitive user data.

5. Responsible Research Rules

Security researchers are requested to:

- Avoid accessing other people's funds or private information.
- Avoid disrupting public network services.
- Avoid destructive testing against systems they do not own.
- Use local or authorized testnet environments whenever possible.
- Avoid publicly disclosing an unpatched vulnerability.
- Give maintainers reasonable time to investigate and resolve the issue.

Researchers must not exploit vulnerabilities to steal funds, extort users, or damage infrastructure.

6. Acknowledgement and Triage

After a reporting channel is operational, maintainers should aim to:

- Acknowledge receipt within 3 business days.
- Perform an initial severity assessment within 7 business days.
- Request additional information when necessary.
- Keep the reporter informed of significant progress.

These are proposed response targets, not guaranteed service-level commitments.

7. Severity Classification

Reports should be classified according to actual impact and exploitability.

Severity| Description| Example
Critical| Direct threat to consensus integrity or user funds at large scale| Unauthorized creation of valid coins
High| Serious compromise or major financial/security impact| Remote private-key theft
Medium| Limited but meaningful security weakness| Unauthorized access to restricted node functionality
Low| Minor security issue with limited impact| Information exposure with minimal sensitivity

Severity must be assessed using technical evidence rather than assumptions.

8. Investigation Process

The maintainers should follow this process:

1. Receive the report securely.
2. Record the report and assign an internal tracking ID.
3. Confirm the affected component and version.
4. Reproduce the issue in an isolated environment.
5. Assess exploitability and potential impact.
6. Identify affected releases and network versions.
7. Develop a mitigation or security fix.
8. Perform independent review where appropriate.
9. Test the fix.
10. Prepare a coordinated disclosure plan.

Consensus-critical vulnerabilities require particular care because an incorrect fix may split the network or create incompatible chain histories.

9. Security Fix and Release Process

Security fixes must follow:

- Secure code review.
- Appropriate regression tests.
- Reproducible build procedures.
- Release signing and verification.
- Documented upgrade instructions.
- Emergency communication when required.

For consensus-critical changes, the project must document activation rules and compatibility implications before deployment.

A security patch must not silently change monetary policy or consensus rules.

10. Coordinated Disclosure

The project should coordinate public disclosure with the reporter.

A public security advisory should normally include:

- Vulnerability identifier, if assigned.
- Affected versions.
- Severity.
- Technical impact.
- Fixed versions.

- Upgrade instructions.
- Mitigation guidance.
- Researcher acknowledgement, if permission is granted.

Sensitive exploit details should not be published while users remain exposed, unless disclosure is necessary to prevent greater harm.

11. Emergency Security Response

If an actively exploited or critical vulnerability is discovered, maintainers should:

1. Activate the "Incident_Response_Plan.md".
2. Identify affected nodes, wallets, and services.
3. Establish a secure incident communication channel.
4. Prepare and review emergency mitigations.
5. Notify affected operators through verified channels.
6. Coordinate network upgrades if required.
7. Preserve logs and relevant forensic evidence.
8. Publish a post-incident report when safe.

Emergency changes must still receive appropriate technical review.

12. Researcher Recognition

The project may acknowledge responsible security researchers in public advisories or a future security acknowledgements page.

Any financial reward or bug bounty programme must be separately approved and funded.

Current bug bounty status: Not established.

No payment or reward is promised under this policy.

13. Privacy and Confidentiality

Security reports should be treated as confidential.

Maintainers should:

- Restrict access to people who need the information.
- Avoid sharing reporter identities without permission.
- Protect submitted proof-of-concept materials.
- Avoid storing unnecessary personal information.
- Follow applicable privacy and data protection requirements.

14. Related Documents

This policy should be read together with:

- "Security_Spec.md"
- "Threat_Model.md"
- "Incident_Response_Plan.md"
- "Release_Management_Plan.md"
- "Backup_Policy.md"
- "Testing_Strategy.md"
- "Code_of_Conduct.md"

15. Policy Status

This document is a proposed security policy.

Before public launch, SAECOIN must establish:

- An official security email or secure reporting channel.
- Responsible security maintainers.
- A vulnerability handling and tracking process.
- A private communication procedure.
- A public advisory process.

Until those arrangements are in place, this document must not be presented as an operational security response service.

End of Document